

ESTADO DESEADO Y PLAN DE ACCIÓN

Seguridad preventiva y de respuesta en redes de datos

► **Areli Alejandra Guevara Badillo**

► *Miércoles, 20 de octubre de 2025*

1. Introducción y Alcance

Este documento finaliza el ciclo de análisis de seguridad de la red doméstica. Tras haber completado el inventario de activos (MT1), la auditoría de configuraciones (MT2) y el análisis de brechas (MT3), esta memoria técnica tiene como objetivo definir la postura de seguridad deseada y establecer un plan de trabajo detallado para alcanzarla.

El propósito de este documento es transformar el análisis en acción. Se presentarán las contramedidas necesarias para mitigar los riesgos identificados, se definirán nuevos controles y se establecerá un cronograma de implementación priorizado, asumiendo la total responsabilidad de su ejecución.

2. Definición del Estado Deseado a Alcanzar

El objetivo estratégico es evolucionar la red desde su estado actual, un entorno plano, con confianza implícita y defensas permisiva, hacia un modelo de seguridad maduro basado en dos principios fundamentales de la ciberseguridad moderna:

1. **Defensa en Profundidad:**

Este principio dicta que la seguridad no debe depender de una única barrera.

Se implementarán múltiples capas de defensa. Si una capa falla, otras capas seguirán protegiendo los activos críticos.

2. **Confianza Cero (Zero Trust):**

Se abandonará la suposición de que los dispositivos dentro de la red son inherentemente seguros.

En el estado deseado, ningún dispositivo tendrá acceso sin restricciones a otros.

Para materializar estos principios, el estado deseado se define a través de los siguientes cuatro pilares:

- **Pilar 1: Perímetro Fortalecido y de Mínima Exposición.**

El router, como puerta de entrada a la red, será "endurecido". Se minimizará su superficie de ataque deshabilitando todos los servicios no esenciales e inseguros (WPS, UPnP). La autenticación, tanto para la administración del router como para el acceso Wi-Fi, será extremadamente robusta, haciendo inviables los ataques de fuerza bruta.

- **Pilar 2: Visibilidad, Control y Autorización Total de Activos.**

Se erradicarán los "puntos ciegos". El estado deseado es aquel donde cada dispositivo conectado es conocido, documentado y explícitamente autorizado, en cumplimiento con el **CIS Control 1**. No se permitirá la conexión de ningún dispositivo que no haya sido aprobado previamente, moviendo la red de un modelo de "permitir por defecto" a uno de "denegar por defecto".

- **Pilar 3: Segmentación Lógica de la Red.**

Se implementará una segmentación estricta para contener las amenazas. La red se dividirá en zonas de seguridad, impidiendo que un incidente en una zona de bajo riesgo se propague a una de alto riesgo. Se crearán al menos dos segmentos: una Red de Confianza para dispositivos personales y críticos, y una Red de Aislamiento (utilizando la función de red de invitados) para dispositivos IoT y de visitantes.

- **Pilar 4: Endpoints Asegurados y Resilientes.**

Se reconoce que la seguridad de la red es inútil si los dispositivos finales son vulnerables. El estado deseado incluye que todos los dispositivos gestionados tengan habilitados controles de seguridad fundamentales. Esto incluye la protección de datos en reposo mediante cifrado de disco y la configuración de mecanismos de protección de datos en caso de pérdida o robo, como el borrado remoto.

3. Plan de Trabajo Detallado para la Implementación

A continuación, se presenta el plan de trabajo estructurado en fases lógicas para garantizar una implementación ordenada y efectiva. Cada tarea aborda directamente una o más brechas identificadas en la Memoria Técnica 3.

Responsable de Ejecución: Areli Alejandra Guevara Badillo

Fase 1: Contención Inmediata y Fortalecimiento del Perímetro (Prioridad: Crítica)

El objetivo de esta fase es cerrar las puertas de entrada más obvias y eliminar los riesgos más inminentes.

ID	Tarea	Descripción Detallada de la Actividad
A-01	Fortalecer Credenciales de Acceso	► Acceder a la interfaz de administración del router Huawei. ► Cambiar la contraseña de administrador por una de 20+ caracteres complejos generada por un gestor de contraseñas. ► Generar una nueva frase de contraseña para la red Wi-Fi principal (ambas bandas) de +20 caracteres. ► Documentar las nuevas credenciales en un almacén de contraseñas seguro. ► Reconectar los dispositivos legítimos con la nueva contraseña.
A-02	Deshabilitar Servicios Inseguros	► Acceder a la configuración avanzada del router. ► Navegar a la sección de WLAN y deshabilitar permanentemente Wi-Fi Protected Setup (WPS). ► Navegar a la sección de reenvío de NAT y deshabilitar permanentemente Universal Plug and Play (UPnP). ► Guardar la configuración y reiniciar el router para asegurar que los cambios se apliquen.
A-03	Identificar y Neutralizar Dispositivos Desconocidos	► Intentar obtener más información de los dispositivos con 010 y 012. ► Investigar físicamente para localizar los dispositivos. ► Si son legítimos documentarlos, asignarles un nombre descriptivo y agregarlos al inventario, si no bloquear su dirección MAC de inmediato en el router para revocar su acceso, aplicando el principio de desconfianza.

Fase 2: Implementación de Segmentación y Control de Acceso (Prioridad: Alta)

El objetivo de esta fase es construir las barreras internas para limitar el movimiento lateral de un atacante.

ID	Tarea	Descripción Detallada de la Actividad
B-01	Implementar Segmentación de Red (Red de Invitados)	► Habilitar la función de Red de Invitados en el router. ► Asignarle un nombre (SSID) claro que indique su propósito. ► Configurar una contraseña robusta e independiente de la red principal. ► Localizar y activar la opción "Aislamiento de Cliente". ► Esta es la acción más crítica, ya que impide que los dispositivos en esta red se comuniquen entre sí.
B-02	Migrar Dispositivos de Baja Confianza	► Desconectar el dispositivo IoT (ID 005: Roku Guebadillo) de la red principal. ► Conectar el dispositivo a la nueva red de invitados. ► Establecer como política que todos los dispositivos de visitantes se conecten exclusivamente a esta red.
B-03	Implementar Control de Acceso MAC	► Crear un inventario con todos los dispositivos de confianza. ► habilitar la función de Filtrado de Direcciones MAC en el router en modo "Whitelist" (Lista Blanca / Permitir). ► Añadir cada una de las MAC de los dispositivos de confianza a la lista. Esto asegurará que solo los dispositivos explícitamente autorizados puedan conectarse.

Fase 3: Endurecimiento de Endpoints y Políticas de Usuario (Prioridad: Media)

El objetivo de esta fase es asegurar los activos individuales y establecer buenas prácticas de seguridad.

ID	Tarea	Descripción Detallada de la Actividad
C-01	Habilitar Cifrado de Datos en Reposo	► En las computadoras con Windows Pro, acceder al Panel de Control y activar BitLocker para cifrar la unidad del sistema. ► Durante el proceso, guardar la clave de recuperación en un lugar seguro y separado del dispositivo. ► Informar a los usuarios sobre la importancia de no perder esta clave.
C-02	Estandarizar Seguridad de Smartphones	► En los smartphones gestionados, acceder a la configuración de seguridad y activar la función de "Encontrar mi dispositivo" (Android/iOS), que habilita el borrado remoto. ► Verificar que la opción de instalar aplicaciones de fuentes desconocidas esté deshabilitada en todos los dispositivos.

4. Plan de Acción Detallado por Activo

Para complementar el plan de trabajo general, esta sección desglosa las contramedidas específicas que se aplicarán a cada activo identificado en la red. La siguiente tabla, originada en el inventario de la **Memoria Técnica I**, se reutiliza aquí como una lista de verificación para la remediación.

La columna "Acciones de Seguridad" ha sido actualizada para reflejar las tareas concretas que se ejecutarán en cada dispositivo para alinearlos con el estado de seguridad deseado. Este enfoque granular garantiza que ninguna vulnerabilidad previamente identificada quede sin atender y sirve como un mapa de ruta para la ejecución de las tareas de endurecimiento en cada uno de los componentes de la red.

ID	Nombre	Tipo	Identificación	IPv4	Conexión	Prioridad	Acciones de Seguridad
001	Router Huawei HG8145V5	Infraestructura	48:12:58:F7:8F:6B	187.190.40.123	GPON/LAN	Crítica	Auditar configuración de seguridad (Firewall, UPnP, WPS, Contraseñas). Definir línea base de seguridad.
002	Extensor	Infraestructura	ac:4e:65:96:f7:f0	192.168.100.2	LAN1	Alta	Verificar actualizaciones de firmware. Asegurar que hereda correctamente las políticas de la red principal.
003	DesktopGUEBA	Computadora	d4:be:d9:95:d0:fe	192.168.100.4	LAN3	Alta	Auditar controles de seguridad del SO (Firewall, Antivirus, Actualizaciones, Cifrado de disco).
004	LaptopVenuz (Cable)	Computadora	38:a7:46:0e:6f:69	192.168.100.26	LAN2	Alta	Auditar controles de seguridad del SO (Firewall, Antivirus, Actualizaciones, Cifrado de disco).
005	Roku Guebadillo	IoT	a8:b5:7c:7d:00:cc	192.168.100.18	Wi-Fi (SSID1)	Media	Verificar actualizaciones de firmware. Planificar aislamiento en red de invitados.
006	Redmi-Note-11	Smartphone	aa:60:7f:e3:a3:dd	192.168.100.23	Wi-Fi (SSID1)	Media	Auditar controles (Bloqueo, Cifrado, Borrado remoto). Deshabilitar MAC aleatoria para esta red.

ID	Nombre	Tipo	Identificación	IPv4	Conexión	Prioridad	Acciones de Seguridad
007	Redmi-Note-11	Smartphone	0a:6c:b7:6c:a3:cd	192.168.100.37	Wi-Fi (SSID5)	Media	Auditar controles (Bloqueo, Cifrado, Borrado remoto). Deshabilitar MAC aleatoria para esta red.
008	LaptopVenuz (Wi-Fi)	Computadora	c8:8a:9a:6d:e7:b4	192.168.100.25	Wi-Fi (SSID5)	Media	Auditar controles de seguridad del SO (Firewall, Antivirus, Actualizaciones, Cifrado de disco).
009	DBR-W09	Computadora	42:d4:62:c4:f9:69	192.168.100.36	Wi-Fi (SSID5)	Alta	Identificar dispositivo. Si no es legítimo, bloquear MAC inmediatamente.
010	-	Desconocido	f6:42:6c:aa:ce:c2	192.168.100.11	Wi-Fi (SSID5)	Baja	PRIORIDAD CRÍTICA: Identificar dispositivo. Si no es legítimo, bloquear MAC inmediatamente.
011	dg60774	Computadora	28:d0:43:aa:81:68	192.168.100.21	Wi-Fi (SSID6)	Alta	Auditar controles de seguridad del SO (Firewall, Antivirus, Actualizaciones, Cifrado de disco).
012	-	Desconocido	ae:ee:d1:07:f3:a5	192.168.100.12	Wi-Fi (SSID6)	Baja	PRIORIDAD CRÍTICA: Identificar dispositivo. Si no es legítimo, bloquear MAC inmediatamente.
013	POCO-M5s	Smartphone	da:d6:d3:1b:d6:dd	192.168.100.7	Wi-Fi (SSID5)	Media	Auditar controles de seguridad (Bloqueo, Cifrado, Borrado remoto, Fuentes de apps).

ID	Nombre	Tipo	Identificación	IPv4	Conexión	Prioridad	Acciones de Seguridad
014	Xiaomi-12-Pro	Smartphone	2e:bf:86:af:89:c9	192.168.100.41	Wi-Fi (SSID5)	Media	Identificar dispositivo. Si no es legítimo, bloquear MAC inmediatamente.
015	Xiaomi-12-Pro	Smartphone	ee:97:f4:d7:a7:37	192.168.100.42	Wi-Fi (SSID1)	Media	Identificar dispositivo. Si no es legítimo, bloquear MAC inmediatamente.
016	DBR-W09	Computadora	42:0b:1c:c5:6b:dc	192.168.100.39	Wi-Fi (SSID5)	Alta	Identificar dispositivo. Si no es legítimo, bloquear MAC inmediatamente.
017	HUAWEI_nova_3-a8	Smartphone	88:bf:e4:25:3e:5f	192.168.100.40	Wi-Fi (SSID6)	Media	Eliminar de la red.
018	Xiaomi-12-Pro	Smartphone	2e:bf:86:ae:89:c9	192.168.100.43	Wi-Fi (SSID5)	Media	Auditar controles. Deshabilitar MAC aleatoria para esta red.
019	Redmi-Note-11	Smartphone	5e:8e:2b:f9:3a:45	192.168.100.30	Wi-Fi (SSID5)	Media	Eliminar de la red.
020	Servicio de Telefonía	Servicio VoIP	5511851175	N/A	POTS Port 1	Baja	Considerado servicio gestionado por el proveedor. No se requieren acciones directas.

5. Conclusión Final del Proyecto

La ejecución del plan de trabajo detallado en este documento representa la culminación del ciclo de seguridad, transformando el análisis en una mejora tangible y efectiva. Este plan no es meramente una lista de tareas, sino una estrategia integral diseñada para elevar la red de su estado actual, vulnerable y permisivo, a una postura de seguridad proactiva y resiliente.

Al completar las fases de implementación, desde la contención inmediata de riesgos hasta el endurecimiento de los dispositivos finales, se habrán mitigado sistemáticamente todas las brechas críticas identificadas en el análisis. El resultado será el logro del estado deseado: un entorno de red donde el perímetro está fortalecido, cada activo está bajo control, la segmentación limita el impacto de posibles incidentes y los datos están protegidos.

Este proyecto ha cumplido su objetivo de identificar, analizar y planificar la remediación de las vulnerabilidades. La implementación de este plan no solo corrige las fallas actuales, sino que también establece una base operativa sólida para el mantenimiento continuo de la seguridad, reconociendo que la protección de la información es un proceso constante de vigilancia y adaptación. La red resultante será un entorno digital significativamente más seguro para todos sus usuarios.